Strong authentication and privileged access — Keycloak

Banque Kerlann (fictive) · Keycloak — royaume kerlann (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-11 12:19**

Auditor sign-off: **pending**
Run: **20261111-121909-keycloak-bench-meta**

Owner: **IT department — IAM team**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-11 12:19, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**7** findings	**0** findings closed and verified	**7** open findings
0 human approvals	**114** sensitive data items masked in evidence	**8 min 01 s** audit duration	**$0.504 *** measured AI cost



Critical: 1 High: 3 Medium: 3 Low: 0

Key messages

- 7 findings across 7 controls: 1 critical, 3 high, 3 medium.
- 7 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-KC-01
Entity	Banque Kerlann (fictive)
System	Keycloak — royaume kerlann (fournisseur d'identité)
System criticality	Supports critical or important functions (DORA)
Environment	Test Keycloak (fictitious realm)
Owner	IT department — IAM team
Lead auditor	Attest CI (automated run, no human auditor)
Date	2026-11-11 12:19
Framework	DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4

Audited target	Keycloak (open-source identity provider), through the read-only gateway
Work programme	drafted by AI for this engagement — pending auditor review · controls/AUD-2026-KC-01.en.json

In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-11; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	STATUS	DUE DATE
F-01	PSI-4.1	MFA enforced for privileged administrator accounts	Critical	Non-compliant	Open	2026-12-11
F-02	PSI-4.2	MFA enforced for users of critical system	High	Non-compliant	Open	2027-02-09
F-03	PSI-4.6	Logging of administration actions	High	Non-compliant	Open	2027-02-09
F-04	PSI-4.7	No generic or shared administrator accounts	High	Non-compliant	Open	2027-02-09
F-05	PSI-4.3	Minimum password length and complexity	Medium	Non-compliant	Open	2027-05-10
F-06	PSI-4.4	Account lockout after repeated failures	Medium	Non-compliant	Open	2027-05-10
F-07	PSI-4.5	Inactive session timeout	Medium	Non-compliant	Open	2027-05-10

4. Detailed findings and controls

F-01 PSI-4.1 MFA enforced for privileged administrator accounts

Critical · Non-compliant · Open

CRITERIA

Every account holding the realm role admin must have multi-factor authentication configured.

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `["a.abgrall", "b.cariou", "c.denis", "e.floch", "g.herve", "j.kermarrec", "support-n2"]`

Expected: `totp=true for all users with role admin`

Checked 7 admin users: 7 without MFA.

PROBABLE CAUSE

MFA enrollment for administrators was not enforced at provisioning due to missing configuration or control. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Compromise of a password-only administrator account would allow full takeover of the identity provider.

RECOMMENDATION

Enforce OTP enrollment for all admin accounts and remove privileged access until MFA is configured.

Due date: 2026-12-11 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via GET /api/kc/roles/admin/users and verify totp is true for each account.



At testing — The screenshot corroborates the test. Screenshot lists seven enabled admin accounts each showing MFA as no. · 7/7 sensitive data items masked

`2026-11-11 12:23:33 · SHA-256 d58fa119146e95b5…`

F-02 PSI-4.2 MFA enforced for users of critical system

High · Non-compliant · Open

CRITERIA

Every user account in the Keycloak realm, which supports critical or important functions, must have multi-factor

CONDITION

Observed: `["a.abgrall", "a.allain", "a.bertrand", "a.briand", "a.derrien", "a.floch", "a.fournier", "a.jegou", "a.kerjean", "a.kervella", "a.le-roux",`

authentication configured.

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

`"a.lefebvre", "a.le…`

Expected: `totp=true for all users`

Checked 260 users, 260 without MFA.

PROBABLE CAUSE

MFA was not made mandatory by default for all users due to incomplete authentication flow configuration. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Password-only authentication exposes critical-function accounts to phishing and credential theft.

RECOMMENDATION

Require OTP enrollment for all realm users and disable accounts that have not enrolled.

Due date: 2027-02-09 · Owner: IT department — IAM team

Test procedure: Retrieve all user accounts via GET /api/kc/users with pagination and verify totp is true for each account.

Keycloak · kerlann read-only audit view

User accounts

Accounts 1–100 · 100 per page next page →

USERNAME	REALM ROLE	ENABLED	MFA (OTP CONFIGURED)
a.abgrall	admin	yes	no
a.allain	—	yes	no
a.bertrand	—	yes	no
a.briand	—	yes	no
a.derrien	—	yes	no
a.floch	—	yes	no
a.fournier	—	yes	no
a.jegou	—	yes	no
a.kerjean	—	yes	no
a.kervella	—	yes	no
a.le-roux		yes	no
a.lefebvre	—	yes	no
a.lefloch	—	yes	no
a.madec	—	yes	no
a.mercier	—	yes	no
a.pennec	—	yes	no
a.quere	—	yes	no
a.quere2	—	yes	no
a.quillien		yes	no
a.raoul	—	yes	no
a.robert	—	yes	no
a.roux	—	yes	no
a.roux2	—	yes	no
b.bihan	—	yes	no
b.bonnet	—	yes	no
b.cariou	admin	yes	no
b.cloarec	—	yes	no
b.dupont	—	yes	no
b.even	—	yes	no
b.kerbrat	—	yes	no
b.kerjean	—	yes	no
b.madec	—	yes	no
b.morel	—	yes	no
b.quillien	—	yes	no
b.roux	—	yes	no
b.uguen	—	yes	no
c.abgrall	—	yes	no
c.bertrand	—	yes	no
c.denis	admin	yes	no
c.durand	—	yes	no
c.floch		yes	no
c.guillou	—	yes	no
c.jacq	—	yes	no
c.lagadec	—	yes	no
c.lambert	—	yes	no
c.le-bihan	—	yes	no
c.leroy	—	yes	no
c.madec	—	yes	no
c.quillien		yes	no

c.quillien	—	yes	no
c.quillien2	—	yes	no
c.raoul	—	yes	no
c.raoul2	—	yes	no
c.robert	—	yes	no
c.roux	—	yes	no
c.uguen	—	yes	no
d.jaouen	—	yes	no
d.madec	—	yes	no
d.martin	—	yes	no
d.roux	—	yes	no
e.david		yes	no
e.dubois	—	yes	no
e.floch	admin	yes	no
e.girard	—	yes	no
e.le-gall	—	yes	no
e.le-gall2	—	yes	no
e.lefloch	—	yes	no
e.michel	—	yes	no
e.morel	—	yes	no
e.nedelec	—	yes	no
e.petit	—	yes	no
e.robert	—	yes	no
e.salaun	—	yes	no
e.tanguy	—	yes	no
e.toullec	—	yes	no
e.vincent	—	yes	no
e.vincent2	—	yes	no
f.daniel	—	yes	no
f.guillou	—	yes	no
f.kerjean	—	yes	no
g.bernard	—	yes	no
g.bertrand	—	yes	no
g.even	—	yes	no
g.gourvennec	—	yes	no
g.henaff	—	yes	no
g.herve	admin	yes	no
g.kerjean	—	yes	no
g.lambert	—	yes	no
g.lambert2	—	yes	no
g.laurent	—	yes	no
g.lefloch		yes	no
g.morel	—	yes	no
g.petit	—	yes	no
g.richard	—	yes	no
h.gourvennec	—	yes	no
h.le-roux	—	yes	no
h.moreau	—	yes	no
h.robert	—	yes	no
i.girard	—	yes	no
i.gourmelen	—	yes	no
i.jaouen	—	yes	no

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The page shows accounts 1-100 all with MFA set to no, consistent with the automated failure for missing MFA. · 100/100 sensitive data items masked (90 spotted by the AI, the rest by the deterministic safety net)
`2026-11-11 12:27:48 · SHA-256 37d328ee03a64670…`

F-03 PSI-4.6 Logging of administration actions

High | Non-compliant | Open

CRITERIA

All administration actions must be recorded as admin events.

PSI-4.6 · RTS 12(2)(c)(i)

CONDITION

Observed: `false`
Expected: `adminEventsEnabled=true`

Realm representation shows adminEventsEnabled is False.

PROBABLE CAUSE

Audit event collection was not enabled as part of the logging baseline for the realm. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Without admin audit logging, malicious or erroneous privileged changes cannot be detected or investigated.

RECOMMENDATION

Enable admin events recording for the realm including details and secure retention.

Due date: 2027-02-09 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify adminEventsEnabled is true.

Keycloak · kerlann read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**kerlann**
enabled	**True**
passwordPolicy	**length(8)**
bruteForceProtected	**False**
permanentLockout	**False**
failureFactor	**30**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**28800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**False**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The screenshot shows adminEventsEnabled is False, matching the automated failure.
`2026-11-11 12:24:20 · SHA-256 e79eb04f9c6ce6e9…`

F-04 PSI-4.7 No generic or shared administrator accounts

High | Non-compliant | Open

CRITERIA

No account holding the realm role admin may be generic or shared, each admin must have a nominative username of form initiale.nom and a personal email, not a function identifier or shared mailbox.

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

CONDITION

Observed: `["support-n2"]`

Expected: `for role admin members, username matches initiale.nom pattern and email is personal, no generic username (ops, admin, root) or shared mailbox (ops-partage@, adm…`

Checked 7 admin members, 1 with generic/shared or non-nominative username or email.

PROBABLE CAUSE

Use of operational shared accounts for administration persisted due to missing joiner-mover-leaver and naming controls. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

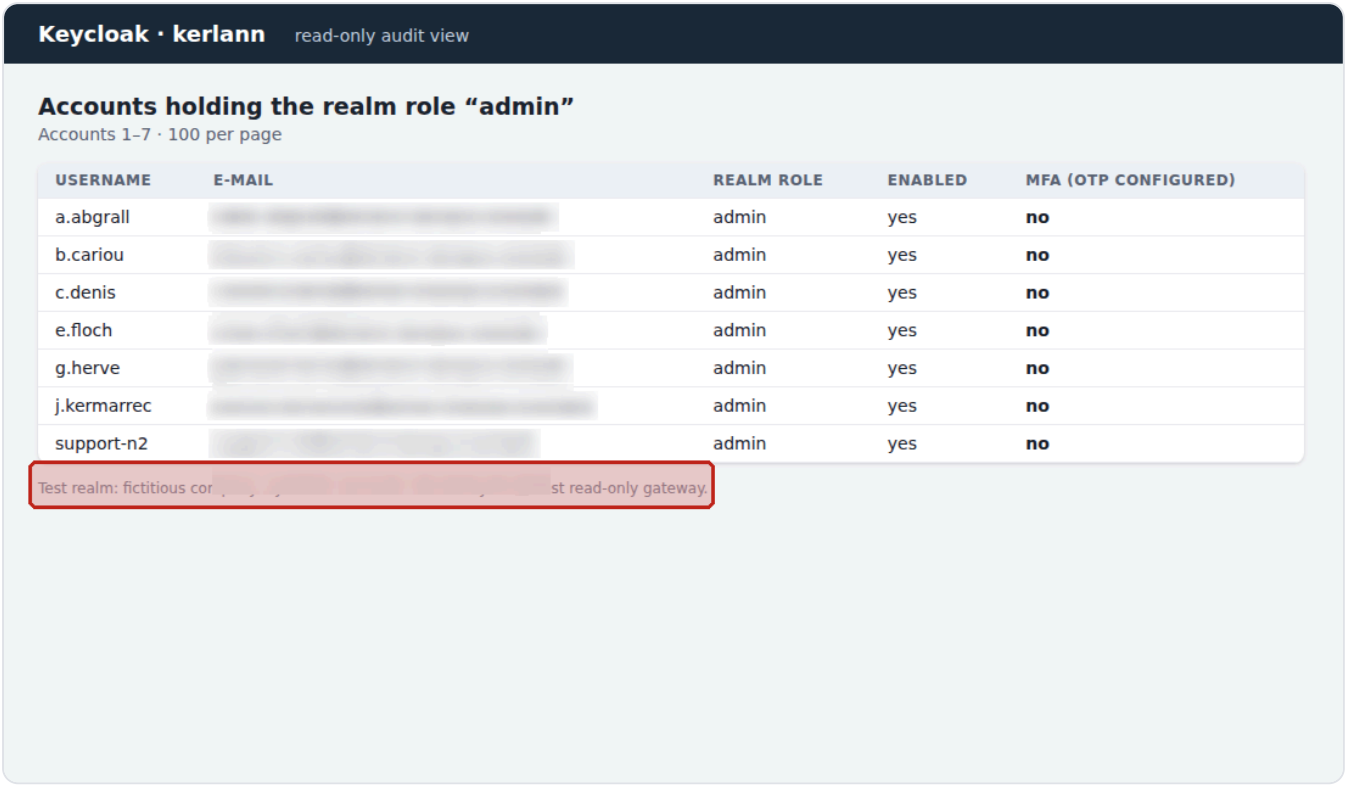
Shared administrator accounts prevent accountability and allow uncontrolled privileged access.

RECOMMENDATION

Remove admin rights from all generic or shared accounts and reissue nominative administrator accounts.

Due date: 2027-02-09 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via GET /api/kc/roles/admin/users and verify username and email are nominative and not generic or shared.



At testing — The screenshot corroborates the test. The last row shows generic account support-n2 holding the admin role, matching the failed test. · 7/7 sensitive data items masked (6 spotted by the AI, the rest by the deterministic safety net)

`2026-11-11 12:26:22 · SHA-256 075d4e08e0c2de75…`

F-05 PSI-4.3 Minimum password length and complexity

Medium | Non-compliant | Open

CRITERIA

Password policy must require at least 12 characters with complexity requirements.

CONDITION

Observed: `length(8)`

Expected: `passwordPolicy contains length(12) and`

PSI-4.3 · DORA 9(4)(d)

`upperCase, lowerCase, digits, specialChars`
Checked 1 realm representation and passwordPolicy does not require length 12 with upperCase, lowerCase, digits and specialChars.

PROBABLE CAUSE

Secure password policy defaults were not applied when the realm was configured. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Weak passwords can be brute-forced or guessed, leading to unauthorized access.

RECOMMENDATION

Set the realm password policy to at least 12 characters with upper/lower case, digits and special characters.
Due date: 2027-05-10 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify the passwordPolicy requires length 12 and complexity.

Keycloak · kerlann read-only audit view

Realm security settings
Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**kerlann**
enabled	**True**
passwordPolicy	**length(8)**
bruteForceProtected	**False**
permanentLockout	**False**
failureFactor	**30**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**28800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**False**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The screenshot shows passwordPolicy as length(8), confirming it does not meet length 12 with complexity.
`2026-11-11 12:22:44 · SHA-256 d0200aee4ad1039f…`

F-06 PSI-4.4 Account lockout after repeated failures

Medium · Non-compliant · Open

CRITERIA

Account lockout must be enabled and trigger after at most 5 failed logins, never disabled.

CONDITION

Observed: `{"bruteForceProtected": false, "failureFactor": 30}`

PSI-4.4 · DORA 9(4)(c)

Expected: `bruteForceProtected=true and failureFactor<=5`

Realm has brute-force protection disabled.

PROBABLE CAUSE

Brute-force protection was left disabled or set too permissively during realm hardening. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Without lockout, attackers can perform unlimited online password guessing against accounts.

RECOMMENDATION

Enable brute-force protection and set the failure threshold to 5 attempts or fewer.

Due date: 2027-05-10 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify bruteForceProtected is enabled with failureFactor at most 5.

Keycloak · kerlann read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**kerlann**
enabled	**True**
passwordPolicy	**length(8)**
bruteForceProtected	**False**
permanentLockout	**False**
failureFactor	**30**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**28800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**False**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. Screenshot shows brute-force protection is False and failureFactor is 30.

`2026-11-11 12:22:29 · SHA-256 b64149ba48aeb937…`

F-07 PSI-4.5 Inactive session timeout

Medium · Non-compliant · Open

CRITERIA

Idle sessions must expire after at most 15 minutes and idle timeout must never be disabled.

PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `28800`

Expected: `ssoSessionIdleTimeout<=900 and >0`

ssoSessionIdleTimeout is 28800 seconds, exceeding 15 minutes.

PROBABLE CAUSE

Session timeout was left at the insecure default value due to missing hardening baseline. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Overly long idle sessions allow session hijacking from unattended workstations.

RECOMMENDATION

Set the SSO idle session timeout to 15 minutes or less.

Due date: 2027-05-10 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify ssoSessionIdleTimeout is set to 900 seconds or less.

Keycloak · kerlann read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**kerlann**
enabled	**True**
passwordPolicy	**length(8)**
bruteForceProtected	**False**
permanentLockout	**False**
failureFactor	**30**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**28800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**False**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. Screenshot shows ssoSessionIdleTimeout is 28800, exceeding the 900-second limit.

`2026-11-11 12:24:33 · SHA-256 4a91e5d4a6ad1f0d…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · MFA enforced for privileged administrator accounts	c87b0847a836caa8 · written by AI for this engagement	Non-compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · MFA enforced for users of critical system	f30b8f7aaae4bd8e · written by AI for this engagement	Non-compliant
DORA 9(4)(d)	PSI-4.3	C3 · Minimum password length and complexity	530be90e49ee24a0 · written by AI for this engagement	Non-compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after repeated failures	ec062ea712f5e48f · written by AI for this engagement	Non-compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	0e29aae0a499362b · written by AI for this engagement	Non-compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	73e5b5747120488e · written by AI for this engagement	Non-compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared administrator accounts	34a9b0b573900068 · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-11 12:23:33	d58fa119146e95b59257987089904650c4e5f02cabb31131bd89e2d42fece6f4
evidence/C2_before.png	C2 · At testing	2026-11-11 12:27:48	37d328ee03a64670ea207ebc8457f8f879327927d5c3745c4a87953d1e5e5cd2
evidence/C3_before.png	C3 · At testing	2026-11-11 12:22:44	d0200aee4ad1039fcb0e8c6e930272dcceb3792bfdc7b80f48e983c22ad6bb80
evidence/C4_before.png	C4 · At testing	2026-11-11 12:22:29	b64149ba48aeb937d23c96e3941b5a9f3a8b07ead2c61a36d1d9bc192b5b9e77
evidence/C5_before.png	C5 · At testing	2026-11-11 12:24:33	4a91e5d4a6ad1f0d69ab76b2e2431d3395e99c401827261a4cdde6ecae0b33f2
evidence/C6_before.png	C6 · At testing	2026-11-11 12:24:20	e79eb04f9c6ce6e954f9e9d625c0c67f02865dfc509b6ca1e569ca89b365e913
evidence/C7_before.png	C7 · At testing	2026-11-11 12:26:22	075d4e08e0c2de7508f4b5a397000ce66e3f2a1ddeabc0199e95a47fc19484a5

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	15	28,668	110,143	0	0.5039

sam-3.1	19	0	0	19	price not published
Total					**0.5039**

Sensitive data (personal data and secrets) in evidence: 103/114 spotted by Muse Spark + SAM, 114/114 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`0530fac92f23fd20e2376bb2b3ba364a494132f9185dce45a97af693c3c76144`